

Security Audit

Primus Labs (DeFi)

Table of Contents

Executive Summary	4
Project Context	4
Audit scope	7
Security Rating	8
Intended Smart Contract Functions	9
Code Quality	10
Audit Resources	10
Dependencies	10
Severity Definitions	11
Status Definitions	12
Audit Findings	13
Centralisation	18
Conclusion	19
Our Methodology	20
Disclaimers	22
About Hashlock	23

CAUTION

THIS DOCUMENT IS A SECURITY AUDIT REPORT AND MAY CONTAIN CONFIDENTIAL INFORMATION. THIS INCLUDES IDENTIFIED VULNERABILITIES AND MALICIOUS CODE WHICH COULD BE USED TO COMPROMISE THE PROJECT. THIS DOCUMENT SHOULD ONLY BE FOR INTERNAL USE UNTIL ISSUES ARE RESOLVED. ONCE VULNERABILITIES ARE REMEDIATED, THIS REPORT CAN BE MADE PUBLIC. THE CONTENT OF THIS REPORT IS OWNED BY HASHLOCK PTY LTD FOR USE OF THE CLIENT.

Executive Summary

The Primus Labs team partnered with Hashlock to conduct a security audit of their smart contracts. Hashlock manually and proactively reviewed the code in order to ensure the project's team and community that the deployed contracts are secure.

Project Context

Primus Labs is a Web3 innovation hub dedicated to advancing blockchain technology through state-of-the-art research, analytics, and infrastructure solutions. The platform is designed to empower developers, investors, and enterprises with robust tools and data-driven insights, enabling them to navigate and capitalize on the evolving decentralized landscape. By integrating cutting-edge technology with a commitment to transparency and security, Primus Labs aims to drive sustainable growth and unlock new opportunities in the digital economy.

Project Name: Primus Labs

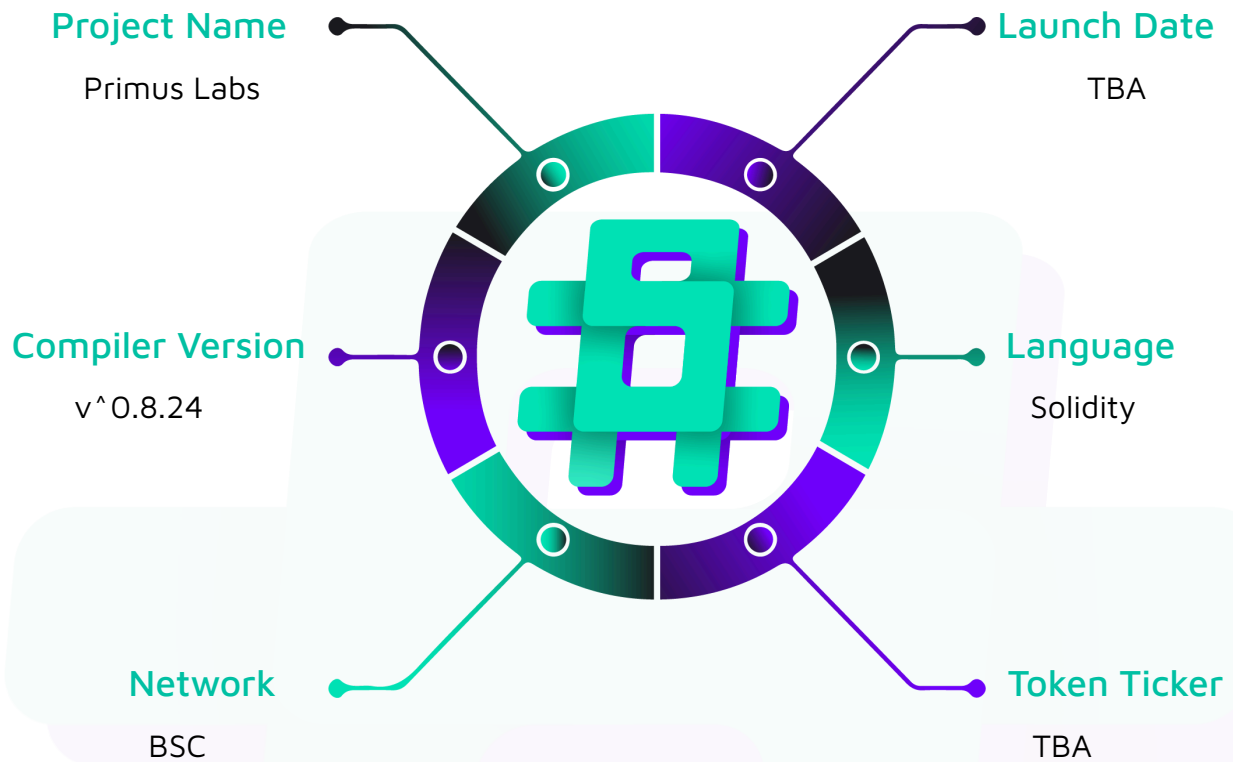
Project Type: Defi

Compiler Version: ^0.8.24

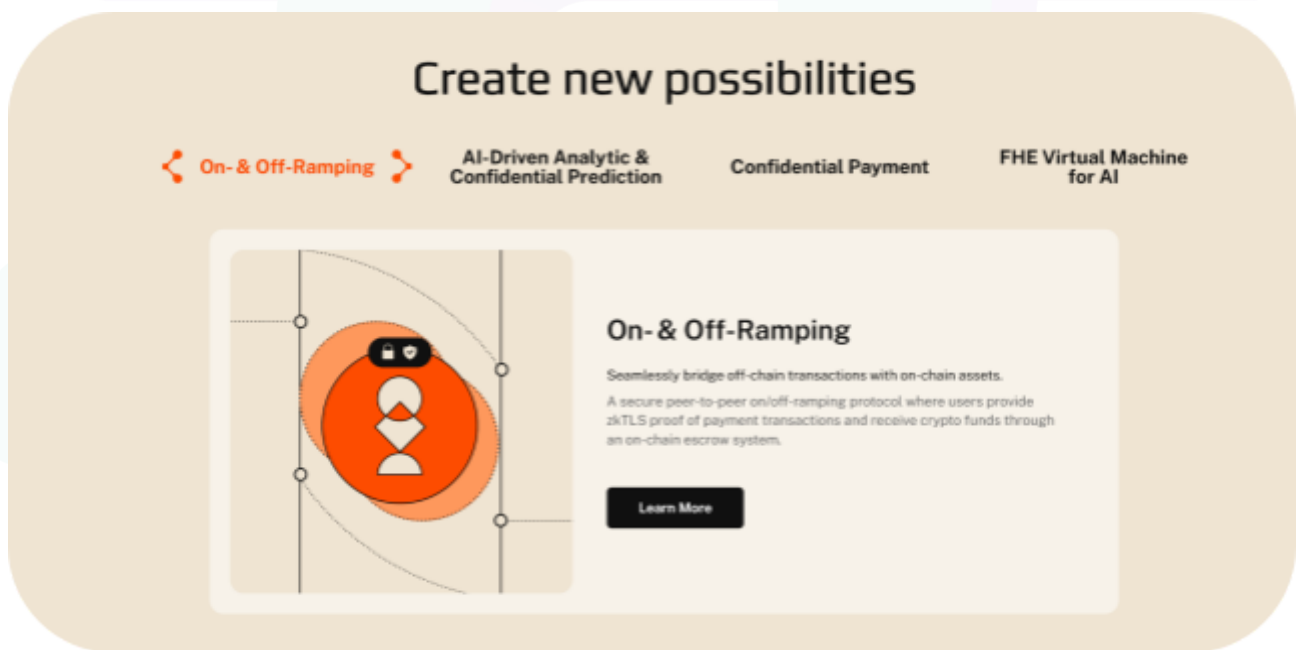
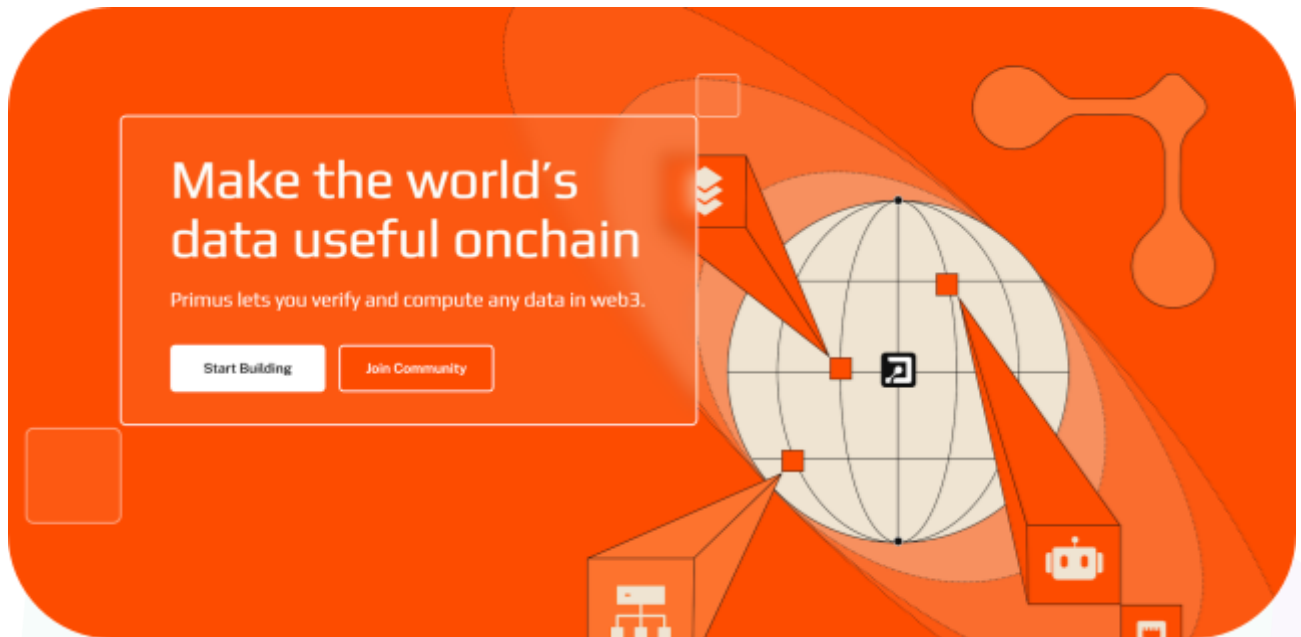
Website: www.primuslabs.xyz

Logo:



Visualised Context:

Project Visuals:



Audit scope

We at Hashlock audited the solidity code within the Primus Labs project, the scope of work included a comprehensive review of the smart contracts listed below. We tested the smart contracts to check for their security and efficiency. These tests were undertaken primarily through manual line-by-line analysis and were supported by software-assisted testing.

Description	Primus Labs Smart Contracts
Platform	BSC / Solidity
Audit Date	February, 2025
Contract 1	BaseFeeDiscountHook.sol
Contract 1 MD5 Hash	80adcfdd9adb4a6bc519ff5d072233ca
Contract 2	AttestationRegistry.sol
Contract 2 MD5 Hash	183501f2a80d672a2d531f39cb2ccf97
Contract 3	BinExchangeVolumeHook.sol
Contract 3 MD5 Hash	e197d39fb3613bf14cf3bba64472e3f0
Contract 4	CLExchangeVolumeHook.sol
Contract 4 MD5 Hash	57348bcbd52dd3b6a182bb4ece0d0704
GitHub Commit Hash	c22f617b3b03ff136242511f2de6eb67673b13e5

Security Rating

After Hashlock's Audit, we found the smart contracts to be **"Secure"**. The contracts all follow simple logic, with correct and detailed ordering. They use a series of interfaces, and the protocol uses a list of Pancake contracts. We initially identified some significant vulnerabilities that have since been addressed.



Not Secure

Vulnerable

Secure

Hashlocked

The 'Hashlocked' rating is reserved for projects that ensure ongoing security via bug bounty programs or on chain monitoring technology.

All issues uncovered during automated and manual analysis were meticulously reviewed and applicable vulnerabilities are presented in the [Audit Findings](#) section. The general security overview is presented in the [Standardised Checks](#) section and the project's contract functionality is presented in the [Intended Smart Contract Functions](#) section.

All vulnerabilities initially identified have now been resolved and acknowledged.

Hashlock found:

1 High severity vulnerability

1 Low severity vulnerability

2 QAs

Caution: Hashlock's audits do not guarantee a project's success or ethics, and are not liable or responsible for security. Always conduct independent research about any project before interacting.

Intended Smart Contract Functions

Claimed Behaviour	Actual Behaviour
AttestationRegistry.sol Records the proofs (attestations) generated by users about their 30-day CEX spot trading volume, using the Primus zkTLS technique.	Contract achieves this functionality.
BinExchangeVolumeHook.sol Hook for Bin pools that checks for the trading history from CEX users.	Contract achieves this functionality.
CLExchangeVolumeHook.sol Hook for CL pools that checks for the trading history from CEX users.	Contract achieves this functionality.

Code Quality

This audit scope involves the smart contracts of the Primus Labs, as outlined in the Audit Scope section. All contracts, libraries, and interfaces mostly follow standard best practices and to help avoid unnecessary complexity that increases the likelihood of exploitation, however, some refactoring was required.

The code is very well commented on and closely follows best practice nat-spec styling. All comments are correctly aligned with code functionality.

Audit Resources

We were given the Primus Labs smart contract code in the form of Github access.

As mentioned above, code parts are well commented. The logic is straightforward, and therefore it is easy to quickly comprehend the programming flow as well as the complex code logic. The comments are helpful in providing an understanding of the protocol's overall architecture.

Dependencies

As per our observation, the libraries used in this smart contracts infrastructure are based on well-known industry standard open source projects.

Severity Definitions

The severity levels assigned to findings represent a comprehensive evaluation of both their potential impact and the likelihood of occurrence within the system. These categorizations are established based on Hashlock's professional standards and expertise, incorporating both industry best practices and our discretion as security auditors. This ensures a tailored assessment that reflects the specific context and risk profile of each finding.

Significance	Description
High	High-severity vulnerabilities can result in loss of funds, asset loss, access denial, and other critical issues that will result in the direct loss of funds and control by the owners and community.
Medium	Medium-level difficulties should be solved before deployment, but won't result in loss of funds.
Low	Low-level vulnerabilities are areas that lack best practices that may cause small complications in the future.
Gas	Gas Optimisations, issues, and inefficiencies
QA	Quality Assurance (QA) findings are informational and don't impact functionality. Supports clients improve the clarity, maintainability, or overall structure of the code.

Status Definitions

Each identified security finding is assigned a status that reflects its current stage of remediation or acknowledgment. The status provides clarity on the handling of the issue and ensures transparency in the auditing process. The statuses are as follows:

Significance	Description
Resolved	The identified vulnerability has been fully mitigated either through the implementation of the recommended solution proposed by Hashlock or through an alternative client-provided solution that demonstrably addresses the issue
Acknowledged	The client has formally recognized the vulnerability but has chosen not to address it due to the high cost or complexity of remediation. This status is acceptable for medium and low-severity findings after internal review and agreement. However, all high-severity findings must be resolved without exception.
Unresolved	The finding remains neither remediated nor formally acknowledged by the client, leaving the vulnerability unaddressed.

Audit Findings

High

[H-01] BaseFeeDiscountHook#_checkAttestations - Incorrect Expiry Check for Attestation Validation

Description

The `_checkAttestations` function is intended to verify whether a user possesses a valid attestation and ensure that the attestation has not expired.

However, due to an incorrect implementation of the expiry check, the function always returns false, even for valid and unexpired attestations.

Vulnerability Details

Every attestation is submitted and stored in the contract with the timestamp of submission.

The `_checkAttestations` function checks whether the current time has passed the `durationOfAttestation` from the submission creation time.

```
if (
    (block.timestamp - attestation.timestamp / 1000) <= durationOfAttestation * 24 * 60
    * 60
    && attestation.value >= baseValue
) {
    return true;
}
```

The current implementation compares `block.timestamp - attestation.timestamp / 1000` to the `durationOfAttestation` in seconds.

However, based on the current block timestamp, `block.timestamp - attestation.timestamp / 1000` is always greater than the `durationOfAttestation` in seconds and the `_checkAttestations` function always returns false.

Proof of Concept

An example of a test that simulates the bug.

```
function testAttestationValidation() public {
    vm.createSelectFork("https://rpc.ankr.com/bsc");
    Attestation[] memory fetchedAttestation =

MockAttestationRegistry(address(iAttestationRegistry)).getAttestationByRecipient(address(
this));

    PoolKey memory poolKey = PoolKey({
        currency0: Currency.wrap(address(0)),
        currency1: Currency.wrap(address(1)),
        hooks: IHooks(address(c1ExchangeVolumeHook)),
        poolManager: c1PoolManager,
        fee: LPFeeLibrary.DYNAMIC_FEE_FLAG,

parameters:
bytes32(uint256(IHooks(address(c1ExchangeVolumeHook)).getHooksRegistrationBitmap())).setT
ickSpacing(
        10
    )
});

    ICLPoolManager.SwapParams memory swapParams = ICLPoolManager.SwapParams({
        amountSpecified: 1000, // Example amount
        sqrtPriceLimitX96: 0, // Replace with appropriate value
        zeroForOne: true // Example direction
    });

    c1PoolManager.initialize(poolKey, Constants.SQRT_RATIO_1_4);

    //update fee

    vm.prank(c1ExchangeVolumeHook.owner());
```

```

    clExchangeVolumeHook.updatePoolFeeByPoolKey(poolKey, 3000);

    vm.startPrank(address(clPoolManager), address(clPoolManager));

    (bytes4 selector2, BeforeSwapDelta beforeSwapDelta2, uint24 fee2) =

        clExchangeVolumeHook.beforeSwap(address(clPoolManager), poolKey, swapParams,
abi.encode("0"));

    // The fee2 is assumed to be discounted but it is still 3000.

    assertTrue(fee2 == 3000, "fee2 is not equal");

    vm.stopPrank();
}

```

Impact

Users can not even execute the `beforeSwap` with the discounted fee even if they have valid attestations.

Recommendation

Update the attestation expiry check correctly.

Note

Hashlock has found H-01 to be incorrect due to a comment reporting that the `attestation.timestamp` function is in `timestamp` considering the function to be measured in seconds. However, the Primus Labs team informed that the function is generated by their SDK which defines `timestamp` to be in milliseconds allowing the developers to get a more accurate time.

Status

Acknowledged

Low

[L-01] **AttestationRegistry#setPrimusZKTLS, setSubmissionFee, setFeeRecipient, setCexAndJsonPath, BaseFeeDiscountHook#setDefaultFee, setBaseValue, setDurationOfAttestation, setAttestationRegistry** - Missing events

Description

The above functions are missing events when key states are updated.

Recommendation

Add a relevant event in the function.

Status

Resolved

QA

[Q-01] **Contracts** - Floating pragma

Description

The contracts have `pragma solidity ^0.8.24` and it might allow the contracts to be deployed with a different version than the one used for testing.

Different pragma versions being used in test and mainnet may pose unidentified security issues.

Recommendation

Specify a specific version of Solidity in the pragma statement.

Status

Resolved

[Q-02] BaseFeeDiscountHook - Unused error declarations

Description

The `BaseFeeDiscountHook` contracts declares `NotSupportedExchange`, `AttestationExpired`, and `NoAttestationEligibility` errors but they are not used in the contracts.

Having unused error declarations on production could reduce the code quality.

Recommendation

Remove the unused error declarations.

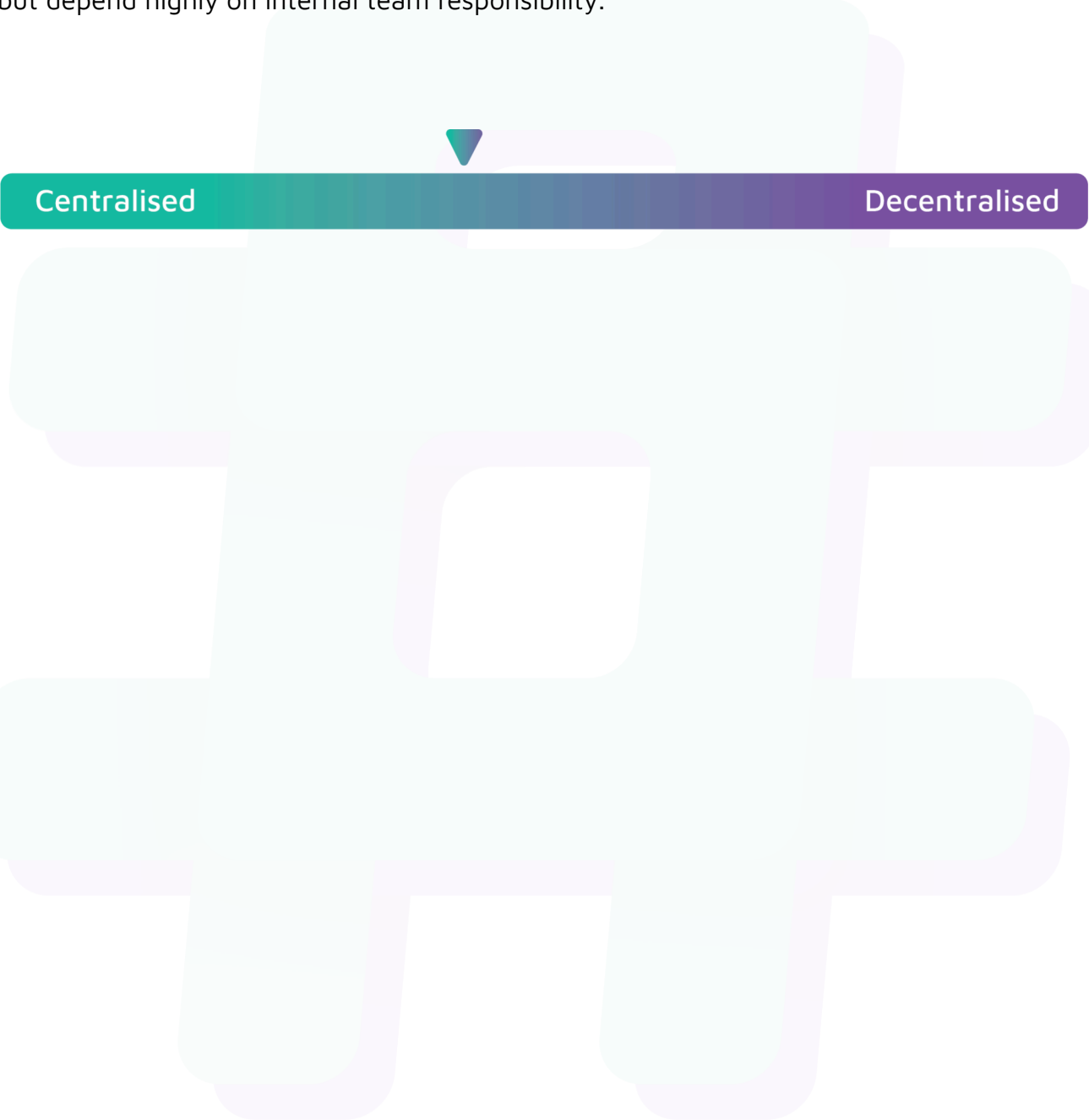
Status

Resolved

Centralisation

The Primus Labs values security and utility over decentralisation.

The owner executable functions within the protocol increase security and functionality but depend highly on internal team responsibility.



Centralised

Decentralised

Conclusion

After Hashlock's analysis, the Primus Labs seems to have a sound and well-tested code base, now that our vulnerability findings have been resolved and acknowledged. Overall, most of the code is correctly ordered and follows industry best practices. The code is well commented on as well. To the best of our ability, Hashlock is not able to identify any further vulnerabilities.

Our Methodology

Hashlock strives to maintain a transparent working process and to make our audits a collaborative effort. The objective of our security audits is to improve the quality of systems and upcoming projects we review and to aim for sufficient remediation to help protect users and project leaders. Below is the methodology we use in our security audit process.

Manual Code Review:

In manually analysing all of the code, we seek to find any potential issues with code logic, error handling, protocol and header parsing, cryptographic errors, and random number generators. We also watch for areas where more defensive programming could reduce the risk of future mistakes and speed up future audits. Although our primary focus is on the in-scope code, we examine dependency code and behaviour when it is relevant to a particular line of investigation.

Vulnerability Analysis:

Our methodologies include manual code analysis, user interface interaction, and white box penetration testing. We consider the project's website, specifications, and whitepaper (if available) to attain a high-level understanding of what functionality the smart contract under review contains. We then communicate with the developers and founders to gain insight into their vision for the project. We install and deploy the relevant software, exploring the user interactions and roles. While we do this, we brainstorm threat models and attack surfaces. We read design documentation, review other audit results, search for similar projects, examine source code dependencies, skim open issue tickets, and generally investigate details other than the implementation.

Documenting Results:

We undergo a robust, transparent process for analysing potential security vulnerabilities and seeing them through to successful remediation. When a potential issue is discovered, we immediately create an issue entry for it in this document, even though we have not yet verified the feasibility and impact of the issue. This process is vast because we document our suspicions early even if they are later shown to not represent exploitable vulnerabilities. We generally follow a process of first documenting the suspicion with unresolved questions, and then confirming the issue through code analysis, live experimentation, or automated tests. Code analysis is the most tentative, and we strive to provide test code, log captures, or screenshots demonstrating our confirmation. After this, we analyse the feasibility of an attack in a live system.

Suggested Solutions:

We search for immediate mitigations that live deployments can take and finally, we suggest the requirements for remediation engineering for future releases. The mitigation and remediation recommendations should be scrutinised by the developers and deployment engineers, and successful mitigation and remediation is an ongoing collaborative process after we deliver our report, and before the contract details are made public.

Disclaimers

Hashlock's Disclaimer

Hashlock's team has analysed these smart contracts in accordance with the best industry practices at the date of this report, in relation to: cybersecurity vulnerabilities and issues in the smart contract source code, the details of which are disclosed in this report, (Source Code); the Source Code compilation, deployment, and functionality (performing the intended functions).

Due to the fact that the total number of test cases is unlimited, the audit makes no statements or warranties on the security of the code. It also cannot be considered as a sufficient assessment regarding the utility and safety of the code, bug-free status, or any other statements of the contract. While we have done our best in conducting the analysis and producing this report, it is important to note that you should not rely on this report only. We also suggest conducting a bug bounty program to confirm the high level of security of this smart contract.

Hashlock is not responsible for the safety of any funds and is not in any way liable for the security of the project.

Technical Disclaimer

Smart contracts are deployed and executed on a blockchain platform. The platform, its programming language, and other software related to the smart contract can have their own vulnerabilities that can lead to attacks. Thus, the audit can't guarantee the explicit security of the audited smart contracts.

About Hashlock

Hashlock is an Australian-based company aiming to help facilitate the successful widespread adoption of distributed ledger technology. Our key services all have a focus on security, as well as projects that focus on streamlined adoption in the business sector.

Hashlock is excited to continue to grow its partnerships with developers and other web3-oriented companies to collaborate on secure innovation, helping businesses and decentralised entities alike.

Website: hashlock.com.au

Contact: info@hashlock.com.au



#hashlock.